SIMULAÇÃO AUTORIZADA · CENÁRIO FICTÍCIO

Simulação de Engenharia Social

Modelo A — Spear Phishing (E-mail)

Nada é enviado a pessoas reais. Alvo fictício, RoE assinada antes de qualquer contato — reconhecimento, pretexto, roteiro e ciclo de ataque aplicados ao Modelo A.

Cybersecurity Offensive: Pentest & Red Team · Trabalho de Pós-Graduação

Victor Caldas dos Santos

Escopo da simulação e Regras de Engajamento (RoE)

Fora do escopo assinado, nada é executado

1

Cenário simulado

A prática acontece em ambiente simulado — nunca contra pessoas reais sem consentimento.

2

Autorização prévia

Escopo e Regras de Engajamento (RoE) assinados antes de qualquer reconhecimento ou contato.

3

Alvo fictício, sem dano

Empresa e personagens são fictícios. Sem exposição pública e sem constranger quem "caísse" no teste.

4

Tipo de exercício

Campanha de phishing simulada — um dos três formatos vistos em aula, ao lado de vishing/pretexting e red team humano.

5

Fim em conscientização

Termina em medição e treinamento, não em pegadinha.

Cenário fictício do ataque

Contexto

NortePay Soluções Financeiras (fictícia) está trocando o ERP financeiro por uma plataforma em nuvem, com a consultoria CloudFin.

É um projeto real dentro da empresa — vira o gancho: qualquer e-mail sobre "validação" ou "novo sistema" soa normal para quem está na área financeira agora.

Alvo

Renata Souza — Analista Fiscal, 3 anos de casa. Cuida da apuração de obrigações fiscais, o que a torna um alvo certo para um pretexto financeiro.

VETOR

Spear phishing

CANAL

E-mail corporativo

ESTÁGIO DO CICLO

Hook (engajamento)

Reconhecimento — achados públicos

Cada dado coletado em fontes abertas (OSINT) alimenta diretamente o pretexto do e-mail

FONTE	ACHADO	USO NO PRETEXTO
LinkedIn	Perfil de Renata mostra cargo (Analista Fiscal) e 3 anos de casa.	→ escolher o alvo certo no financeiro.
Vaga de emprego publicada	Anúncio cita apoio à migração para o novo ERP financeiro em nuvem.	→ gancho de contexto real ("novo sistema").
Post do CIO no LinkedIn	CIO comemora a parceria com a "CloudFin Consultoria".	→ nome de fornecedor real dá legitimidade ao remetente.
Site institucional / rodapé de e-mails em PDF	Padrão de endereço: nome.sobrenome@nortepay.com.br.	→ forjar domínio look-alike (nortepay-corp.com).
Página "Cultura" do site	Expediente divulgado: 9h às 18h.	→ define a janela de urgência (prazo até o fim do expediente).

Vetor escolhido e gatilho psicológico

VETOR

Spear phishing por e-mail

Mensagem escrita para Renata Souza — não um disparo em massa. Usa o vocabulário da migração de ERP que ela já acompanha.

Domínio look-alike no remetente e o nome de um fornecedor real (CloudFin) para reduzir a desconfiança.

GATILHO DE CIALDINI

Autoridade + Urgência

A **Autoridade:** remetente se passa pela TI/Diretoria, reforçado pelo nome da CloudFin — reduz o questionamento da instrução.

U **Urgência:** prazo até 18h e ameaça de bloqueio das obrigações fiscais — pressiona a agir sem checar o link.

Por que funciona: Autoridade + Urgência + contexto real (a migração de ERP).

Pretexto e roteiro — mensagem exata

Modelo de e-mail usado na simulação (link é um placeholder — nada é enviado de verdade)

De: ti.suporte@nortepay-corp.com (domínio look-alike de nortepay.com.br)

Para: renata.souza@nortepay.com.br

Assunto: [Ação necessária] Validação de acesso — Migração ERP até 18h

---

Olá, Renata,

Por causa da migração para o novo ERP, é preciso revalidar seu acesso ao módulo fiscal no novo portal **até hoje às 18h**, senão suas obrigações fiscais em aberto ficam bloqueadas até a próxima janela.

🔗 **[PLACEHOLDER — link de validação do novo portal]**

Qualquer dúvida, responda este e-mail.

Atenciosamente,
Equipe de TI — Diretoria Financeira
NortePay Soluções Financeiras

Ciclo de ataque aplicado ao cenário

1

Investigação

RECONHECIMENTO

LinkedIn, vaga de emprego, post do CIO e site da NortePay: monta o perfil de Renata e o pretexto da migração de ERP.

2

Hook

ENGAJAMENTO

Envio do e-mail com domínio look-alike, explorando autoridade (TI/Diretoria) e urgência (prazo até 18h).

3

Iniciar

EXPLORAÇÃO

Na simulação, clique e preenchimento no portal de teste viram apenas métrica — nenhum dado real é coletado.

4

Saída

DESVINCULAÇÃO

Portal mostra confirmação genérica ("solicitação recebida") e encerra o contato sem levantar suspeita.

Encerramento e conscientização

O objetivo nunca é expor quem "caiu" — é medir, treinar e fortalecer o processo

Métricas da simulação

Taxa de clique, taxa de reporte (a mais importante) e tempo até reportar.

Sem exposição individual

Ninguém que caiu no teste é identificado ou exposto — RoE proíbe constrangimento e dano.

Cultura sem punição

Canal fácil para reportar; resultado serve para treinar, não para punir.

Fecha em plano

Resultado vira plano: onde treinar e o que reforçar, dentro do escopo assinado (RoE).